Introduction

Social Engineering attacks are one of the most common attacks faced by the digital economy. People still fall for online conspiracy theories, pranks, intriguing offers, and paid reviews for various products online, which shows why these attacks still exist today. In a Social Engineering Attack, the threat actor exploits human errors to steal sensitive information. People fall victim to Social Engineering Attacks due to, lack of knowledge- can't distinguish between a credible and fraudulent website, lack of knowledge of security indicators- many users don't know the significance of the closed padlock sign, Visual deception- falling for attractive images, text messages and lack of attention to and the absence of security indicators (Dhamija et al. 2006). After all, 95% of cyber incidents occur due to human errors or behavior (WEF 2022). The best example is the WannaCry attack that originated in 2017 which took the whole NHS by storm and could have been avoided by simply updating Windows at that time. Even before WannaCry, in terms of cyber security, no security measures were taken, even though the whole NHS fraternity knew about the emerging threats. This is called Optimism Bias, where one underestimates the risk (Cherry 2022). The psychology of bias and its significance in cyberspace is important. To create well-maintained security, it is imperative to understand the roadblocks in cyber security depend on comprehending and overcoming bias (Cunningham 2020).

The most common Social Engineering Attacks are Phishing (sending malicious links, emails, images, and messages to access sensitive information), Baiting (making the victim do the tasks which the victim wants to do), Quid Pro Quo (seeking information in exchange for money) and Tailgating (threat actor dresses up as one of the employees of an organization gets access to restricted areas) (ENISA ca 2020). Threat actors use these techniques to exploit the personality, traits, and trust of the victims. For example, many people blindly trust ads/emails/messages from famous companies like Amazon, just the logo is enough to fool them. People with these traits need to be well educated, not just for the sake of themselves but also for the organization that they are working for.

Twilio, a cloud communication platform used for customer engagement, went through a series of sophisticated Social Engineering Attacks (Phishing) on August 4th, 2022. The threat actor used SMS Phishing and Vishing techniques to access the credentials of Twilio employees, customer data, and internal systems of the organization (Twilio 2022). Current and former employees of Twilio received text messages with URL links containing the words “Twilio”, “Okta”, and “SSO”, which opened to a fake website of Twilio, tricking users to give out sensitive information. Moreover, the same threat actor used voice messages to access sensitive information from Twilio employees (Twilio 2022). This report will analyze how, when, and why this attack happened to Twilio with a detailed investigation of the anatomy of the attack which contains the timeline of events, the cyber kill chain framework, and the psychological and technical vulnerabilities exploited by the threat actor. Followed by the impact analysis of the risks, threats, and vulnerabilities, their effects, and knock-on effects.

Anatomy of the attack

- **Timeline of events**

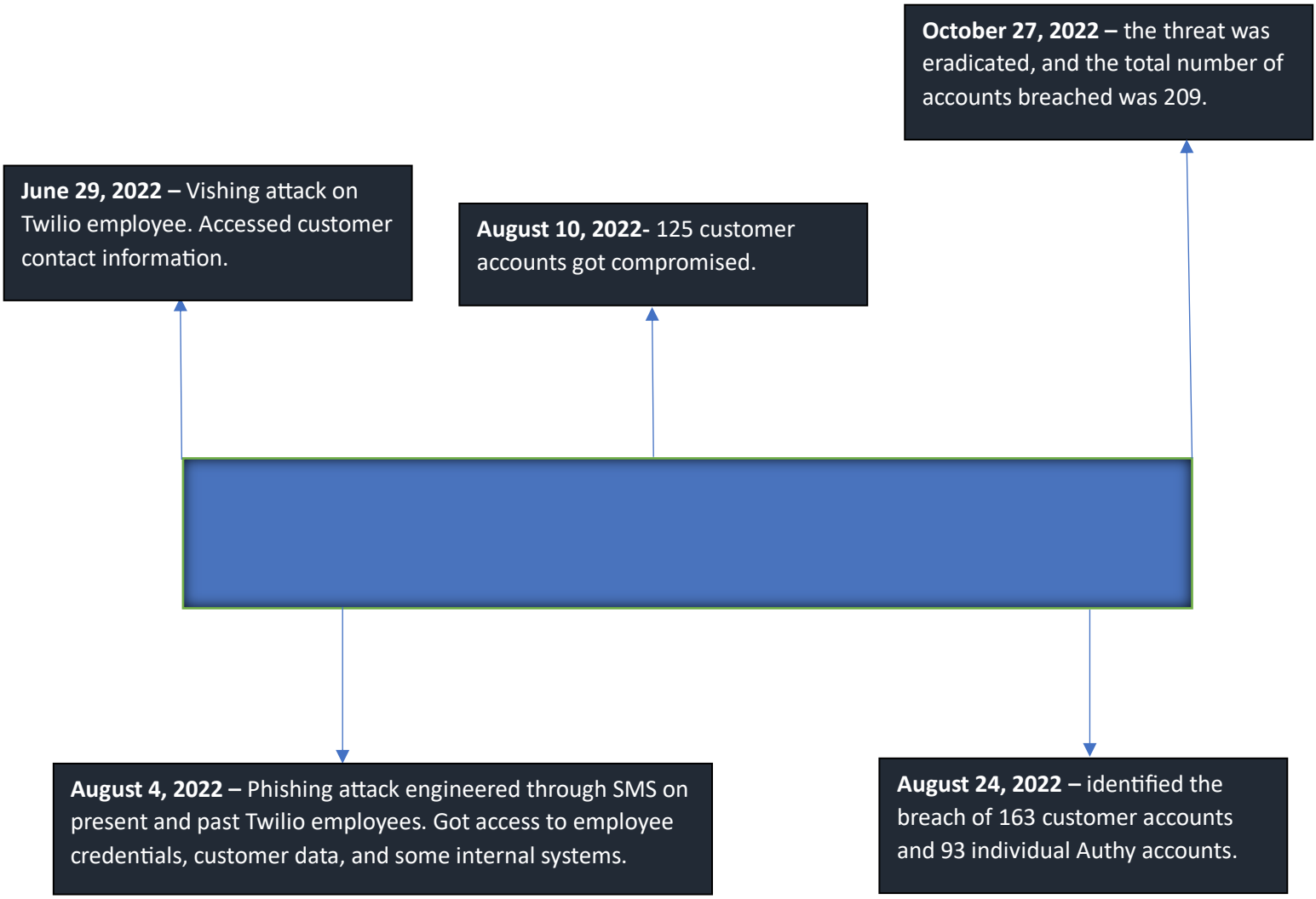

Fig 1 – Attack Timeline (Twilio 2022)

- **Social Engineering Attack Framework**

Goal	To gain credentials, access internal systems, money
Target	Business, Software, Communication Platforms, Food delivery
Social Engineer	ScatterSpider/Oktapus
Communication	Bidirectional Communication
Medium	SMS, Telephone
Technique	Phishing (SMS and Vishing)
Compliance Principles	Authority, Scarcity

Table 1 – SEAF

Cyber Kill Chain Framework

The kill chain framework which was invented by Lockheed Martin in 2011 is used for threat identification and eradication. The framework consists of seven stages.

Reconnaissance	Selecting and gathering information about the organisation and its employees through ZoomInfo, Dehashed.
Weaponization	Establishing the attack techniques- here it is Phishing, Vishing, Sim swapping, usage of VPN, creating a telegram, and fake login pages.
Delivery	Injecting the malware into the victim, here through malicious SMS messages and voice calls.
Exploitation	Technical side -Anydesk (Remote Access Tool), BlackLotus UEFI bootkit. Psychological side -Trust and cognitive biases exploited.
Installation	Rotating through network providers and Anydesk to control the attack, BYOVD, and BlackLotus to overcome firewalls.
Command and Control	Communication and control through Anydesk, VPN to maintain constant connections.
Action On Objective	Accessing customer data, gaining control of internal systems, ransom.

Table 2 – Cyber Kill Chain Framework

1. **Reconnaissance**

   This is the first stage in which the threat actor does a lot of research about the organization (through websites like ZoomInfo, Dehashed), its revenue and profit, contact info such as telephone number, email address of the employees, events conducted, press releases, etc. Twilio's net worth is a total of 11.17 billion (Macrotrends 2023). And it is one of the most profitable software companies of 2022 generating a profit of 3.83 billion which is 30% more than the previous year (Twilio 2022). Famous companies that use Twilio include Signal, Airbnb, Dell, Hulu, Lyft, Reddit, Uber, and DoorDash. So why target Twilio? The answer to that question can be divided into two,

   a) Money
   b) The actual target is the companies that employ Twilio.

Also, Twilio has a section for the press on their website which releases their events and quarterly reports. Since the attack came through the Twilio employee there is a huge chance that the threat actor made use of Twilio's events in choosing the victims.

2. Weaponization

This is the preparation and staging phase of the cyber-attack. The technique used here is Phishing- Smishing and Vishing. For obtaining the credentials, cloned version of the Twilio login page is created using fake Okta, Azure, Duo, and other login pages. Malicious SMS is designed. Assuming the OS used by the threat actor is Kali Linux, site cloning can be done through SETool (Social Engineering) Kit application. A telegram channel is created to collect the compromised data (GROUP-IB 2022). Generated Remote Monitoring Access Tools, AnyDesk, and VPN for accepting Bitcoin as payments (Thomas 2023).

3. Delivery

The stage where the threat actor releases the malware to the victim. On 29th June 2022, the threat actor was able to access employee credentials and customer data through voice phishing. Through this gained information the threat actor sends numerous malicious messages to the present and past employees of Twilio on August 4th, 2022, urging them to change their passwords (Twilio 2022). Sample SMS messages are shown below.

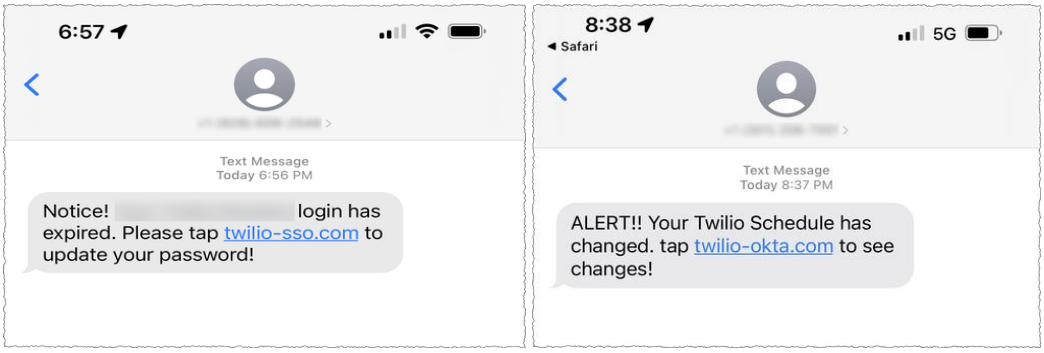

Fig 2 – Sample Messages (Twilio 2022)

Cold-called network providers giving out mobile numbers to transfer into the SIM card controlled by the malicious actor, gained OTP access to log into various accounts of the customers (Thomas 2023).

4. Exploitation

This is the stage where the threat actor gains access to the victim by exploiting vulnerabilities which can be either technical or human vulnerabilities. In this case, the threat actor posed as Twilio IT and insisted the victims to give out their credentials. Behaviors vulnerable to Social Engineering Attacks are listed below.

Behavior
1. Trust
2. Helpful
3. To get something for nothing.
4. Curiosity
5. Fear
6. Ignorance
7. Carelessness

Table 3 -Behaviours Exploited (Gulati 2006)

Here, "**Trust**" which is the expected behavior from the entity i.e., Twilio is exploited by the threat actor. After all, Trust is an essential ingredient of economic life (Alos-Ferrer et al. 2019). From Fig -2, the compliance principles used in the attack are "**Authority**" and "**Scarcity**" (Cialdini 1984). *"Your login has expired", "Update your password"*, these messages create a sense of **Urgency** and **Fear** in the victim, giving them less time to react, which is exactly what Scarcity is (Kirwan et al. 2013). *"Alert, Your Twilio Schedule has changed"* is an authoritative message, making it look like it is directly coming from Twilio which lured the victim to click on the link. This clearly indicates that the attacks are highly sophisticated, and the attacker is well-resourced and motivated.

Compliance Principles	Influence
1. Reciprocity	People always expect something back when they give in to something.
2. Social Proof	The power of peer pressure. We are following what others are saying.
3. Commitment & Consistency	We have the urge to be consistent and we are most likely committed enough to see it through.
4. Liking	The urge to say yes to the people we like.
5. Authority	People are more likely to listen to the ones who are experts in a particular field.
6. Scarcity	The less available, the more valuable.

Table 4 – Compliance Principles (Cialdini 1984)

The cognitive biases exploited are,

a) Inattentional Blindness – missing the smallest details, which are readily visible to us can cause damage. Here the victims failed to notice the fake URL, which could have been avoided by reading closely (Simons and Chabris 1999).

b) Anchoring Bias – relying too much on the first piece of information. The messages were made to look like they came directly from Twilio, which made many users click the link without even thinking twice (MasterClass 2021).
c) The Halo effect – the impression of an entity influences the behavior of the person (MasterClass 2021). The good impression of Twilio on its customers is another reason the attack got successful.

On the technical side, BlackLotus UEFI Bootkit was exploited to disable Bitlocker and Windows Defender (Thomas 2023).

5. **Installation**

The stage where the threat actor establishes a foothold against the victim. Here the threat actor rotated through carriers and hosting providers to continue the SEA on the victims (Twilio 2022). BlackLotus is manipulated to disable firewalls, and Bring-Your-Own-Vulnerable-Driver (BYOVD) is used to bypass Windows kernel protections (Thomas 2023).

6. **Command and Control**

Here, the threat actor communicates with the malware to complete the objective of the attack (EC-Council 2021). Installed AnyDesk which is a Remote Access Tool to the victims' devices to control and monitor their actions and data silos, and used VPNs to maintain connections (Thomas 2023).

7. **Action On Objective**

This is the final stage of the Kill Chain Framework. Only after completing the first six stages, a threat actor can proceed to this stage. Here, the threat actor accomplishes the objectives. And they are as follows,

a) Credential collections – Employee credentials were collected using Voice and SMS Phishing.
b) Privilege escalation – password and OTP collected through fake login pages, hence accessing privilege rights for various user accounts.
c) Internal Reconnaissance – accessed internal administrative systems, tools, and applications to gather customer information.
d) Lateral movement through the environment through carrier rotation maintaining control over the victim.
e) Asking a huge ransom for financial gains.

Impact Analysis

- **Risk Data**

Vulnerability	Threat	Risk
1. Lack of awareness and training standards. (Medium)	Social Engineering Attacks. (High)	Loss of data, credentials, Finances, and documents. (High)
2. Past employee info (Medium)	Access to proprietary info (High)	Leak of sensitive data. (High)
3. SMS services (High)	Smishing attacks (High)	Loss of accounts, passwords, two-factor authentication. (High)
4. Lack of antivirus (High)	Malware (High)	Corrupt data, compromised internal systems. (High)

Table 5 – Risk Data

In the above table, the probability of Vulnerability, Threat, and Risk is represented using three words with three distinct colors.

a) High = 70-100%
b) Medium = 30-69%
c) Low = 0-29%

- **Risk and Impacts**

1. **Loss of credentials, data, finances, and documents** – here the threat is SEA (Phishing, Vishing). The vulnerability exploited is the lack of awareness and training standards of the victims. The impact caused is as follows,
    a) **Increase in stress level and anxiety** – data given out by the employee can be crucial for the company since it is a human error, he or she has the potential risk of losing their job.
    b) **Denial** – the user who has no awareness about cyber-attacks can be in shock and disbelief.
    c) **Depression** – the victim may be financially struggling and, in this case, the Twilio employee with the risk of losing the job can feel helpless.
    d) **Anger** – the victim can put the blame on themselves for getting attacked.
    e) **Shame** – the feeling of the whole incident is caused by the personal mistake of oneself can end up feeling a lot of shame.

2. **Leak of sensitive data** – here the threat is the access of proprietary info through the vulnerability which the available data about past employees. The impacts caused are as follows,
    a) Reputation damage
    b) Loss of customers and revenue
    c) Regulatory fines (iMATAG 2023)

3. **Loss of accounts, passwords, and two-factor authentication** – here the threat is Smishing attacks, and exploited vulnerability is SMS services. The impacts caused are,
    a) Loss of trust – malicious messages were written in the name of Twilio to change the passwords of the victims, hence leading to the bereavement of Trust.
    b) Loss of customers and revenue
    c) Reputation damage

4. **Corrupt data and compromised internal systems** – this threat is assumed to be caused by malware, exploiting the vulnerability- lack of antivirus. This situation is hypothetical here but a necessary one because of the increase in cyber-attacks. The impacts caused are,
    a) Data loss
    b) Asset takeover
    c) Revenue and reputation loss
    d) Loss of customers.

- **Knock-on effects.**

As there were a lot of other companies which employ Twilio as Signal, which got affected when the threat actor registered many users accounts to new mobile devices, which caused disruption for many users, as roles got reversed, and their data is accessed which can be both private and sensitive information that depends on the users (IB-GROUP 2022). All the user data was sent to a telegram channel, and even though the channel was eradicated, we do not know if the data, which was collected by the threat actor was saved to their devices. If so another massive attack with respect to the collected data could occur targeting multiple organisations at the same time which can be fatal as massive disruption of services can occur, followed by revoking access to important internal systems, software, and files and asking for a ransom to get the lost control back, which will disrupt the lives of millions who are a part of the targeted organisation. Food delivery apps such as DoorDash which employed Twilio got breached through the exploitation of Okta pages and customer information was accessed, as these apps save payment options on their apps which can be through credit/debit/PayPal attaining information about these can be very crucial as a lot of customers could face financial loss which can lead to debt for many

people who used DoorDash and Okta, which can lead to reputation loss for not protecting customer data for the organisation (Thomas 2023).